

Enterprise AI Governance Handbook

A concise operating guide for establishing ownership, inventory, risk decisions, controls, evidence, and continuous improvement across enterprise AI use.

How to use this resource

Assign one accountable owner, work through each section with security, legal, procurement, IT, and the business sponsor, then save decisions and evidence with the vendor or AI program record.

1. Establish the operating model

Make AI ownership and decision rights visible.

- [] Name an executive sponsor and accountable owners across security, privacy, legal, procurement, IT, and business teams.
- [] Define which decisions are centralized and which may be made by departments.
- [] Create one intake path for AI tools, models, agents, connectors, and high-impact use cases.
- [] Set review cadences for the program, vendors, models, incidents, exceptions, and performance.

2. Build the inventory

A useful inventory connects technology to purpose, data, people, and evidence.

- [] Record owner, users, workflow, model, vendor, deployment, data classes, regions, connectors, and lifecycle state.
- [] Include pilots, embedded AI features, browser tools, APIs, agents, and employee-purchased services.
- [] Link each item to risk assessment, approval, contract, controls, tests, training, and incidents.
- [] Define discovery methods and a process for reconciling unknown or duplicate tools.

3. Classify risk and approve use

Risk should be assessed at the workflow level, not only the vendor level.

- [] Evaluate impact, affected people, decision authority, data sensitivity, autonomy, reversibility, and regulatory context.
- [] Define prohibited, restricted, pilot, approved, and deprecated states with clear entry and exit criteria.
- [] Require human review and appeal paths where outputs may materially affect people or critical operations.
- [] Document accepted risk, exceptions, compensating controls, owner, expiry date, and reassessment triggers.

4. Put controls into daily work

Policies should become technical and operational defaults.

- [] Enforce identity, role access, model allowlists, data handling, regional routing, retention, and spend limits.
- [] Use approved workflow templates for recurring work and require approval before consequential agent actions.
- [] Provide contextual warnings, safe alternatives, escalation routes, and role-based training.
- [] Keep audit evidence for policy decisions, redactions, overrides, tool calls, approvals, and model changes.

5. Measure and improve

Operate AI governance as a living management system.

- [] Track adoption, blocked events, sensitive-data detections, exceptions, incidents, model changes, cost, quality, and user outcomes.
- [] Review metrics by workflow and risk tier so high activity is not confused with business value.
- [] Test controls regularly and record failures, corrective actions, owners, deadlines, and verification evidence.
- [] Retire unused workflows, revoke access, preserve required records, and migrate users to approved alternatives.

Reference frameworks

Use the latest applicable versions and confirm legal requirements with qualified counsel for your jurisdiction and use case.

NIST AI Risk Management Framework: <https://www.nist.gov/itl/ai-risk-management-framework>

NIST Cybersecurity Framework 2.0: <https://www.nist.gov/cyberframework>

OWASP Top 10 for LLM Applications: <https://owasp.org/www-project-top-10-for-large-language-model-applications/>

ISO/IEC 42001 overview: <https://www.iso.org/standard/81230.html>